

Hands-On-Learning: Attack Path Modeling: Creating Attack Trees with Deciduous

Learning Objective

By the end of this activity, learners will be able to:

- Distinguish between threats, vulnerabilities, and risks in practical security scenarios
 - Create structured attack trees using the Deciduous web application
 - Apply the STRIDE methodology concepts to identify attack vectors
 - Map attacker goals, attack steps, and security mitigations in a visual tree structure
-

- Analyze attack paths to identify critical security gaps and prioritize defensive measures
- Convert threat modeling findings into actionable security recommendations

Description

This focused hands-on lab introduces learners to practical attack path modeling using Deciduous, a free web-based attack tree generator. Students will work with a sample system scenario to create a visual representation of potential attack paths, understand how attackers might achieve their goals, and identify where security mitigations can break the attack chain. The lab emphasizes the practical application of threat modeling concepts and demonstrates how attack trees provide structured visualization of security threats.

Structure of the Activity

Tools used

Deciduous web application (<https://www.deciduous.app/>)

Web browser

Sample system scenario (cloud storage bucket)

Scenario

Your organization has deployed a cloud storage bucket containing sensitive customer data (e.g., customer records, financial documents, or compliance audit files). As a security analyst, you've been tasked with conducting a threat modeling exercise to identify potential attack paths that could lead to unauthorized access to this sensitive data. Using attack tree methodology, you need to systematically map out how an attacker might achieve their goal of accessing the stored data, identify critical attack vectors, and recommend security mitigations. This exercise will help you understand how attackers think and plan their attack strategies, enabling you to design more effective defensive measures.

Objective

Create a comprehensive attack tree that maps potential attack paths against a cloud storage system, identifies key vulnerabilities, and recommends security mitigations to break the attack chain.



Instructions for learners

1 Access Deciduous and Examine the Interface

Navigate to <https://www.deciduous.app/> in your web browser

Observe the default example showing an S3 bucket attack tree

Familiarize yourself with the interface: text editor on the left, visual tree on the right

Note the color coding: attacks (red), mitigations (blue), goals (purple)

Click on various nodes in the tree to see how they correspond to text entries

2 Declare Facts About Your Sample System

Clear the default content and start with a new attack tree

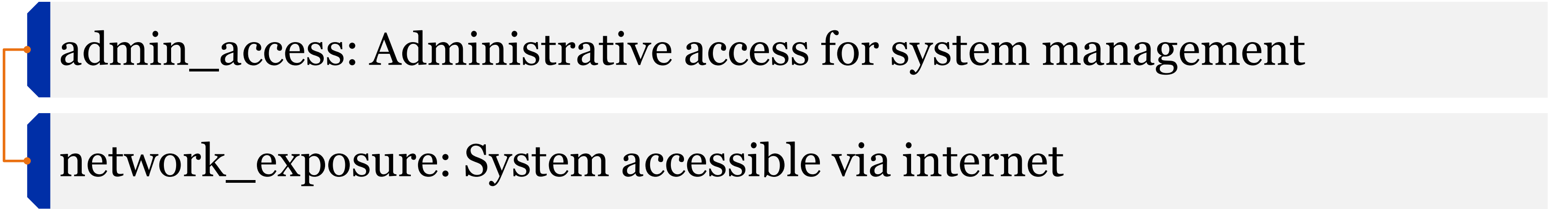
Define your scenario using the following template:

title: Attack Tree for Customer Data Storage Bucket

facts:

cloud_storage_bucket: Cloud storage bucket contains sensitive customer data

web_application: Web application provides user access to stored files



admin_access: Administrative access for system management

network_exposure: System accessible via internet

user_authentication: Basic username/password authentication

Observe how the facts appear as gray nodes at the top of your tree

3 Map Out Initial Attacker Steps

Define the primary attack paths using STRIDE methodology concepts:

attacks:

credential_compromise: Compromise user credentials

from:

facts

exploit_web_app: Exploit web application vulnerabilities

from:

facts

social_engineering: Social engineering attack on employees

from:

facts

insider_threat: Malicious insider access

from:

facts

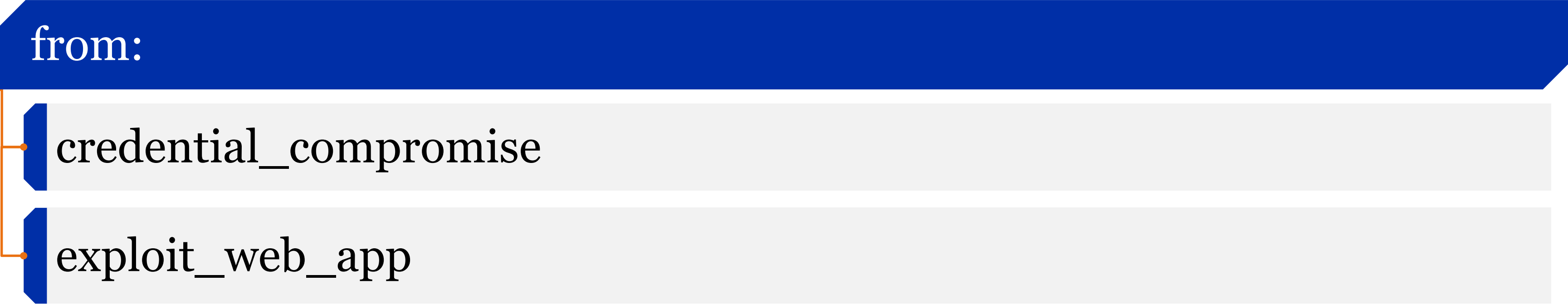
api_abuse: Abuse application programming interface

from:

credential_compromise

privilege_escalation: Escalate privileges to admin level

from:



```
graph TD; Root[from:] --- C1[credential_compromise]; Root --- C2[exploit_web_app];
```

credential_compromise

exploit_web_app

Watch how the attack tree visualizes these connected attack paths

4 Add Security Mitigations

Implement security controls that can break the attack chain:

mitigations:

multi_factor_auth: Implement multi-factor authentication

from:

- credential_compromise

- input_validation: Implement proper input validation and sanitization

from:

- exploit_web_app

- security_awareness: Regular security awareness training

from:

- social_engineering

- access_controls: Implement least privilege access controls

from:

insider_threat

privilege_escalation

- api_rate_limiting: Implement API rate limiting and monitoring

from:

api_abuse

Observe how mitigations (blue nodes) connect to and potentially block attack paths

5 Define the Attacker's Final Goal

Specify the ultimate objective the attacker is trying to achieve:

goals:

data_exfiltration: Access and exfiltrate sensitive customer data

from:

- api_abuse

- privilege_escalation

Ensure all successful attack paths lead to this goal node (purple)

Verify that your attack tree shows complete attack chains from facts to goal

6 Analyze and Report on Findings

Review your completed attack tree and identify:

The most direct attack paths to the goal

Attack paths that lack sufficient mitigations

Critical mitigations that block multiple attack vectors

Areas where additional security controls might be needed

Take a screenshot of your completed attack tree

Document key insights about attack path prioritization and mitigation effectiveness

Organize Information Following This Structure for Peer Review

1. Title Page:

Project title: "Attack Path Modeling Lab: Cloud Storage Security Analysis"
Your name, date, system analyzed

2. Requirement 1: System Facts and Attack Surface Analysis

List the key facts declared about your system

Identify the primary attack surface areas

Explain how these facts influence potential attack vectors

3. Requirement 2: Attack Path Analysis and Risk Assessment

Document the major attack paths identified in your tree

Analyze which attack paths pose the highest risk

Explain the relationship between different attack steps and how they chain together

Include your attack tree screenshot with annotations highlighting critical paths

4. Requirement 3: Mitigation Strategy and Security Recommendations

- List all security mitigations implemented in your attack tree
- Analyze which mitigations provide the greatest security value
- Recommend additional security controls based on gaps identified
- Prioritize mitigations based on their ability to break multiple attack chains

Instructions for Documenting and Sharing the Project for Peer Review



1. Document the Project

Use word processing software to create your report.

Insert the diagram, map, screenshot, or image directly into your Word document, if available.

Ensure all sections of the project document structure are completed.

Proofread and edit your report for clarity and accuracy.



Share the Project

Save your report and presentation in PDF format.

Upload your documents to the “Peer Review” area in the course shell.

Provide a brief description of your project in the submission post.



Peer Review

Review the projects submitted by your peers.

Provide constructive feedback and comments on their work.

Additional Resources and References:

Deciduous Documentation: <https://github.com/rpetrich/deciduous>

STRIDE Methodology Guide: Microsoft STRIDE threat modeling framework

OWASP Threat Modeling Guide: https://owasp.org/www-community/Threat_Modeling

Attack Trees by Bruce Schneier:
https://www.schneier.com/academic/archives/1999/12/attack_trees.html